ESCOLA DA NUVEM

Trabalho de Conclusão de Curso para a certificação em AWS e No Code

Alexandre Ferreira Barbosa
Ezequiel Elisel Farias Carrizo
Leonardo Sena De Jesus
Matheus De Oliveira Santos
Sergio Adriano Faria
Waleska Pereira Marques

A Jornada da Startup NuvemTech

Gestão de Documentos para IA com Arquitetura Serverless na AWS

Brasil – 2026

A Jornada da Startup NuvemTech: Gestão de Documentos para IA com Arquitetura Serverless na AWS

Trabalho de Conclusão de Curso apresentado à Escola da Nuvem como requisito para a obtenção da certificação em AWS e No Code.

Orientador(a): Isaque Alcantara.

Brasil, 2026

Dedicatória

[Às nossas famílias e a todos que nos apoiaram ao longo desta jornada.]

Agradecimentos

Agradecemos à Escola da Nuvem, aos professores e ao(à) orientador(a) pelo conhecimento e pelo acompanhamento durante a formação; aos colegas de equipe, pela colaboração na construção deste trabalho; e aos nossos familiares, pelo apoio e pela paciência.

Epígrafe

"Tudo falha, o tempo todo."
Werner Vogels

Resumo

Este trabalho apresenta o projeto de uma arquitetura serverless na Amazon Web Services (AWS) para a NuvemTech, startup SaaS em hipercrescimento que lançará um Agente de IA para extração inteligente de dados em documentos (PDFs e imagens). A estimativa é de 50 mil novos arquivos por mês, e a empresa definiu que nenhum arquivo pode ser excluído, pois o acervo histórico será o ativo intelectual para o treinamento de futuros modelos de IA. A pesquisa, de natureza aplicada e exploratória, foi conduzida como estudo de caso, com levantamento de requisitos, revisão da documentação oficial da AWS, modelagem da arquitetura e estimativa de custos. A solução combina Amazon API Gateway (entrada dos documentos), AWS Lambda (processamento e consulta isolada por usuário) e Amazon S3 (armazenamento, controle de acesso e Lifecycle), com transição automática dos objetos para uma classe de armazenamento de baixo custo após 365 dias. Os resultados esperados são isolamento total entre clientes, acesso exclusivo por URL assinada, retenção perpétua dos dados e redução expressiva do custo de armazenamento de longo prazo, com economia estimada de cerca de 76% no custo mensal após cinco anos de acervo.

Palavras-chave: AWS; Serverless; Amazon S3; Lifecycle; Inteligência Artificial.

Abstract

This paper presents a serverless architecture on Amazon Web Services (AWS) for NuvemTech, a fast-growing SaaS startup launching an AI agent for intelligent data extraction from documents (PDFs and images). About 50,000 new files are expected each month, and no file may ever be deleted, because the historical collection is the intellectual asset for training future AI models. The research is applied and exploratory, conducted as a case study based on requirements analysis, official AWS documentation and cost estimation. The solution combines Amazon API Gateway (document intake), AWS Lambda (processing and per-user queries) and Amazon S3 (storage, access control and Lifecycle), automatically moving objects to a low-cost storage class after 365 days. The expected outcomes are full isolation between customers, access only through signed URLs, permanent data retention and a significant reduction in long-term storage costs.

Keywords: AWS; Serverless; Amazon S3; Lifecycle; Artificial Intelligence.

Lista de figuras

Figura 1 – Arquitetura geral da solução (documentos entram pela API e esfriam no S3 após 365 dias)

Figura 2 – Isolamento de usuários por prefixo no S3 (a chave do objeto nasce do token, nunca da requisição)

Figura 3 – Ciclo de vida dos documentos no S3 (após 365 dias o documento esfria e nunca é excluído)

Lista de tabelas

Tabela 1 – Requisitos do case

Tabela 2 – Requisitos funcionais

Tabela 3 – Requisitos não funcionais

Tabela 4 – Classes de armazenamento do S3

Tabela 5 – Serviços AWS e suas funções na arquitetura

Tabela 6 – Endpoints da API

Tabela 7 – Decisões de projeto e alternativas consideradas

Tabela 8 – Premissas da estimativa de custos

Tabela 9 – Estimativa de custos mensais de armazenamento

Tabela 10 – Controles de segurança

Tabela 11 – Cenários de falha e resposta planejada

Tabela 12 – Plano de testes

Tabela 13 – Mapeamento entre requisitos, solução e demonstração

Tabela 14 – Glossário de termos

Lista de abreviaturas e siglas

ABNT – Associação Brasileira de Normas Técnicas

ACL – Access Control List

API – Application Programming Interface

AWS – Amazon Web Services

CDK – Cloud Development Kit

CI/CD – Integração e entrega contínuas

IA – Inteligência Artificial

IAM – Identity and Access Management

JWT – JSON Web Token

KMS – Key Management Service

LGPD – Lei Geral de Proteção de Dados

PDF – Portable Document Format

RPO – Recovery Point Objective

RTO – Recovery Time Objective

S3 – Simple Storage Service

SaaS – Software as a Service

SQS – Simple Queue Service

SSE – Server-Side Encryption

STS – Security Token Service

TCC – Trabalho de Conclusão de Curso

TLS – Transport Layer Security

UUID – Universally Unique Identifier

Sumário

1. Introdução 1

1.1 Objetivo geral 1
1.2 Objetivos específicos 1
1.3 Justificativa 1
1.4 Problema de pesquisa 2
1.5 Metodologia 2

2. O Case NuvemTech 3

2.1 Cenário 3
2.2 Requisitos do case 3
2.3 Requisitos funcionais 3
2.4 Requisitos não funcionais 4
2.5 Principais desafios e impactos 4

3. Referencial Teórico 5

3.1 Computação serverless 5
3.2 Amazon API Gateway 5
3.3 AWS Lambda 5
3.4 Amazon S3 5
3.5 AWS IAM 5
3.6 Amazon CloudWatch e AWS CloudTrail 5
3.7 Classes de armazenamento do S3 6

4. Arquitetura Proposta 7

4.1 Visão geral 7
4.2 Serviços AWS e suas funções 7
4.3 Decisões de projeto 8
4.4 Endpoints 8
4.5 Organização e fluxo dos dados 8
4.6 Justificativa técnica e alternativas 9

5. Implementação 11

5.1 Bucket S3 11
5.2 Organização por prefixo 11
5.3 Regra de Lifecycle 12
5.4 Permissões da função Lambda (IAM) 12
5.5 Código da função Lambda (Python) 13

6. Estimativa de Custos 16

6.1 Premissas 16
6.2 Resultado da simulação 16
6.3 Pontos de atenção nos custos 17
6.4 Estratégias de otimização 17

7. Segurança e Conformidade 18

7.1 Controles de segurança18
7.2 Identidade e autorização18
7.3 Boas práticas adicionais18
7.4 Preservação e proteção contra exclusão18
7.5 Considerações sobre a LGPD19
8. Escalabilidade, Resiliência e Recuperação20
8.1 Crescimento da demanda20
8.2 Resiliência e falhas20
8.3 Proteção dos dados20
8.4 Recuperação de documentos arquivados20
8.5 Objetivos de recuperação21
9. Monitoramento e Operação22
10. Plano de Testes e Validação23
10.1 Casos de teste23
10.2 Mapeamento dos requisitos23
11. Plano de Demonstração25
12. Melhorias Futuras26
13. Conclusão27
Referências28
Glossário29
Apêndice A – Roteiro de implantação no console da AWS30
Apêndice B – Checklist de revisão do grupo31
Anexos32

1. Introdução

A NuvemTech está lançando uma plataforma SaaS baseada em um Agente de IA capaz de extrair dados de documentos enviados pelos clientes. Esse modelo de negócio gera uma "avalanche" de arquivos que precisam ser recebidos, armazenados com segurança e disponibilizados de volta ao cliente que os enviou.

O desafio central é duplo. De um lado, os clientes precisam acessar seus documentos com rapidez durante o primeiro ano. De outro, a empresa deve preservar todo o histórico indefinidamente para treinar modelos futuros, sem que o custo de armazenamento inviabilize o negócio. Um simples repositório de arquivos não resolve esse problema: é necessária uma arquitetura que una segurança, isolamento de dados e gestão inteligente do ciclo de vida.

1.1 Objetivo geral

Projetar e documentar uma arquitetura serverless na AWS que receba documentos dos clientes, garanta o isolamento entre usuários e arquive automaticamente os dados antigos em camada de baixo custo, sem excluí-los.

1.2 Objetivos específicos

- Disponibilizar uma API para envio de documentos PDF com identificação do usuário.
- Armazenar os arquivos no Amazon S3 organizados por prefixo de usuário.
- Bloquear qualquer acesso público e permitir a leitura apenas pelo dono do arquivo, via URL assinada.
- Configurar regra de Lifecycle que transicione objetos com mais de 12 meses para uma classe fria de armazenamento.
- Implementar uma função Lambda que recupere informações apenas dos arquivos do próprio usuário.
- Estimar o impacto financeiro da estratégia de arquivamento.
- Definir os mecanismos de monitoramento, proteção contra exclusão e recuperação de documentos arquivados.

1.3 Justificativa

A escolha por serverless elimina a administração de servidores, escala automaticamente com a demanda e cobra apenas pelo uso, o que é adequado a uma startup em crescimento acelerado. O S3 oferece durabilidade de 99,999999999% (11 noves) e classes de armazenamento que

permitem reduzir custos conforme o dado envelhece, alinhando-se à necessidade de reter o acervo para IA.

1.4 Problema de pesquisa

Como armazenar um volume crescente de documentos que não podem ser excluídos, garantindo isolamento entre clientes, acesso do usuário por 12 meses e preservação de longo prazo para o treinamento de modelos de IA, sem tornar o custo de armazenamento inviável?

1.5 Metodologia

A pesquisa é de natureza aplicada, com abordagem qualitativa e caráter exploratório, conduzida como estudo de caso da NuvemTech. Os procedimentos foram: (1) levantamento dos requisitos do case; (2) revisão da documentação oficial da AWS sobre S3, Lambda, API Gateway e IAM; (3) modelagem da arquitetura; (4) definição das configurações de segurança e de Lifecycle; (5) estimativa de custos a partir de premissas declaradas; e (6) elaboração de um plano de testes para validar o isolamento e o arquivamento. As ferramentas de apoio foram o console da AWS e a AWS Pricing Calculator.

Este documento descreve uma proposta de arquitetura. Ao longo do texto, o que está **configurado e demonstrável** é distinguido do que é **apenas proposto** (por exemplo, o fluxo de restauração de arquivos e a replicação entre regiões), de modo que nenhum resultado seja apresentado como validado sem evidência.

2. O Case NuvemTech

2.1 Cenário

- **Modelo de negócio:** SaaS com Agente de IA para extração inteligente de dados.
- **Volume estimado:** 50 mil novos arquivos por mês (PDFs e imagens), cerca de 600 mil por ano se o ritmo se mantiver.
- **Regra de retenção:** nenhum arquivo deve ser deletado.
- **Acesso do cliente:** documentos enviados disponíveis por 1 ano.
- **Valor estratégico:** base histórica massiva para treinamento de futuros modelos de IA.

2.2 Requisitos do case

Tabela 1 – Requisitos do case

Tipo	Requisito
Segurança	Isolamento total entre usuários; S3 sem acesso público; leitura apenas via URL assinada pelo dono
Custo	Mover documentos com mais de 365 dias para camada fria de armazenamento
Retenção	Nenhuma exclusão de objetos
Escalabilidade	Suportar crescimento contínuo sem gestão de servidores
Privacidade	Organização por prefixo `usuario-id/` para filtrar permissões

Fonte: elaborado pelos autores (2026).

2.3 Requisitos funcionais

Tabela 2 – Requisitos funcionais

ID	Requisito	Critério de atendimento proposto
RF01	Receber documentos PDF pequenos e a identificação do usuário.	Endpoint de API para iniciar o envio e validar a solicitação.
RF02	Armazenar documentos na AWS.	Guardar os objetos em bucket Amazon S3 privado.
RF03	Consultar documentos do próprio usuário.	A Lambda valida identidade, propriedade do objeto e autorização antes de permitir a leitura.
RF04	Disponibilizar acesso temporário ao arquivo autorizado.	Gerar URL pré-assinada com validade curta, após a validação de acesso.
RF05	Manter os documentos históricos.	Não configurar regra de expiração; restringir exclusões por política de IAM e processo operacional.
RF06	Arquivar documentos após 365 dias.	Regra de S3 Lifecycle para transição a uma classe de arquivamento definida pela equipe.
RF07	Registrar operações relevantes.	Logs de aplicação e métricas no Amazon CloudWatch; auditoria de API conforme configuração adotada.

Fonte: elaborado pelos autores (2026).

2.4 Requisitos não funcionais

Tabela 3 – Requisitos não funcionais

ID	Requisito	Diretriz
RNF01	Segurança e privacidade	Bucket privado, Block Public Access, criptografia, TLS e acesso mínimo necessário.
RNF02	Isolamento entre clientes	Validar o usuário autenticado no backend; não confiar em um ID de usuário enviado livremente pelo cliente.
RNF03	Escalabilidade	Utilizar serviços gerenciados/serverless e evitar servidores permanentemente provisionados.
RNF04	Custo controlado	Transicionar objetos antigos para armazenamento de arquivamento e monitorar consumo.
RNF05	Durabilidade e preservação	Manter objetos sem expiração automática e definir controles contra exclusão acidental ou indevida.
RNF06	Observabilidade	Acompanhar erros, latência, invocações, requisições e custos.
RNF07	Recuperabilidade	Documentar o processo de restauração de objetos arquivados e testar o procedimento.

Fonte: elaborado pelos autores (2026).

2.5 Principais desafios e impactos

- Receber documentos de forma confiável e permitir que o usuário consulte apenas os próprios arquivos.
- Suportar o crescimento do volume sem provisionar servidores permanentemente.
- Preservar os arquivos históricos, sem exclusão automática por política de ciclo de vida.
- Reduzir o custo de armazenamento dos documentos com mais de 365 dias.
- Evitar exposição pública do bucket e acessos indevidos entre clientes.
- Permitir a recuperação de documentos arquivados, considerando que classes de arquivamento podem exigir restauração antes do download.

Uma solução inadequada pode gerar vazamento de documentos entre clientes, perda de dados de valor histórico, indisponibilidade durante picos de uso, aumento desnecessário dos custos e dificuldade para recuperar arquivos antigos. Esses riscos afetam a confiança dos clientes, a continuidade do serviço e a capacidade da NuvemTech de utilizar o acervo como ativo estratégico.

3. Referencial Teórico

3.1 Computação serverless

No modelo serverless, o provedor gerencia a infraestrutura e o desenvolvedor foca na lógica da aplicação. Os recursos escalam automaticamente e a cobrança ocorre por requisição ou tempo de execução. É o caso do AWS Lambda e do Amazon API Gateway.

3.2 Amazon API Gateway

Serviço gerenciado para criar, publicar e proteger APIs. Atua como porta de entrada da solução, recebendo as requisições HTTP, aplicando autenticação e encaminhando-as ao Lambda. Permite ainda limitação de taxa (throttling) e integração com provedores de identidade como o Amazon Cognito.

3.3 AWS Lambda

Serviço de computação orientado a eventos que executa código sem provisionamento de servidores. Na solução, é responsável por gravar documentos, listar os arquivos do usuário e gerar URLs assinadas.

3.4 Amazon S3

Serviço de armazenamento de objetos com alta durabilidade, escalabilidade praticamente ilimitada e diversas classes de armazenamento. Recursos relevantes ao projeto:

- **Block Public Access:** bloqueia acesso público em nível de bucket e conta.
- **URLs assinadas (pre-signed URLs):** concedem acesso temporário a um objeto específico, usando as credenciais de quem as gerou.
- **Lifecycle:** regras que transicionam ou expiram objetos automaticamente.
- **Criptografia em repouso:** SSE-S3 ou SSE-KMS.
- **Versionamento e Object Lock:** o primeiro ajuda a recuperar versões anteriores; o segundo pode impor retenção contra exclusão ou alteração, conforme o modo e o período configurados.

3.5 AWS IAM

Serviço de gerenciamento de identidades e permissões. Aplica-se o princípio do menor privilégio: cada componente recebe somente as permissões estritamente necessárias.

3.6 Amazon CloudWatch e AWS CloudTrail

O CloudWatch reúne logs, métricas e alarmes das aplicações e serviços. O CloudTrail registra chamadas de API da AWS, apoiando a auditoria de ações administrativas e de acesso a dados.

3.7 Classes de armazenamento do S3

Tabela 4 – Classes de armazenamento do S3

Classe	Uso típico	Recuperação
S3 Standard	Acesso frequente	Imediata
S3 Glacier Instant Retrieval	Arquivo com acesso raro, mas imediato	Milissegundos
S3 Glacier Flexible Retrieval	Arquivo com acesso eventual	Minutos a horas
S3 Glacier Deep Archive	Retenção de longo prazo, a menor custo	Horas (padrão em até 12 h; em massa em até 48 h)

Fonte: elaborado pelos autores a partir da documentação da AWS (2026).

Os valores e prazos devem ser conferidos na documentação oficial da AWS, pois podem mudar.

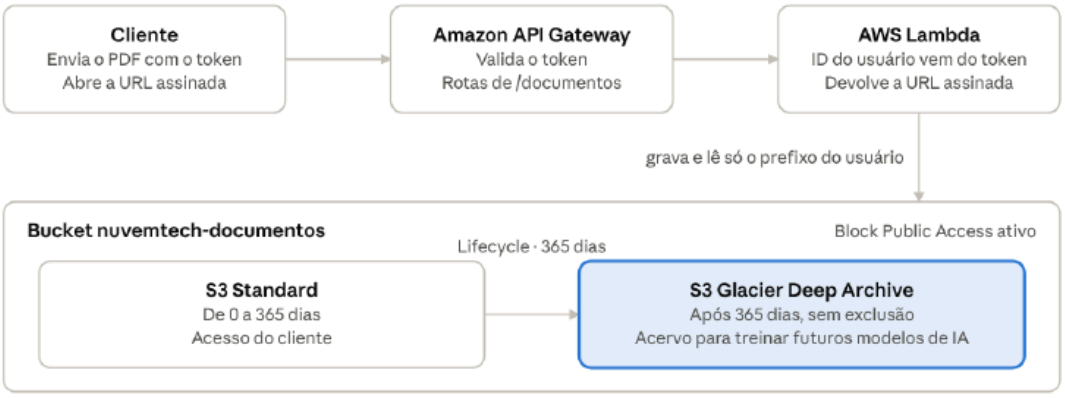
4. Arquitetura Proposta

4.1 Visão geral

A proposta separa a camada de entrada e regras de negócio da camada de armazenamento. Fluxo principal:

1. O cliente autentica-se e envia o PDF ao **API Gateway**, junto com sua identificação.
2. O API Gateway valida o token e aciona a **Lambda**.
3. A Lambda grava o arquivo no **S3** sob o prefixo do usuário (`usuario-123/documento.pdf`).
4. Para consulta, o cliente chama a API; a Lambda lista ou recupera dados **somente** do prefixo do próprio usuário e devolve uma **URL assinada** de curta duração.
5. Uma regra de **Lifecycle** move, após 365 dias, os objetos para a camada fria, sem nunca excluí-los.

Figura 1 – Arquitetura geral da solução (documentos entram pela API e esfriam no S3 após 365 dias)



Fonte: elaborado pelos autores (2026).

4.2 Serviços AWS e suas funções

Tabela 5 – Serviços AWS e suas funções na arquitetura

Serviço	Função	Justificativa e cuidados
Amazon API Gateway	Publica os endpoints para enviar, listar e consultar documentos.	Gerencia a entrada das requisições. Deve usar HTTPS, limites de requisição e autenticação/autorização adequadas.
AWS Lambda	Executa a lógica de negócio: valida identidade, cria chaves de objeto e gera URLs pré-assinadas.	Execução sob demanda e sem servidores. Usa permissões mínimas e nunca confia em um `user_id` enviado pelo cliente.
Amazon S3	Armazena os documentos e aplica a política de ciclo de vida.	Armazenamento de objetos durável e escalável. Manter Block Public Access ativado e permissões restritas.

Serviço	Função	Justificativa e cuidados
S3 Lifecycle	Transfere documentos com mais de 365 dias para uma classe de arquivamento.	Reduz o custo de longo prazo. A regra faz transição, nunca expiração ou exclusão.
AWS IAM	Define as permissões da função e dos operadores.	Privilégio mínimo: a função acessa somente os recursos e operações necessários.
AWS KMS	Gerencia a chave da criptografia em repouso (SSE-KMS).	Dá controle e auditoria sobre o uso da chave; gera custo por uso.
Amazon CloudWatch	Centraliza logs, métricas e alarmes.	Detecta falhas, latência e erros. Evitar registrar conteúdo de documentos, tokens ou dados pessoais.
AWS CloudTrail	Registra chamadas de API para auditoria.	Apoia a investigação de alterações e acessos administrativos; definir retenção e custo dos logs.

Fonte: elaborado pelos autores (2026).

4.3 Decisões de projeto

- **Identidade vem do token, nunca do corpo da requisição.** O ID do usuário usado no prefixo é extraído das claims validadas pelo autorizador (por exemplo, o campo `sub` de um JWT do Cognito). Isso impede que um cliente informe o ID de outro.
- **Sem acesso público.** Os quatro bloqueios do Block Public Access ficam ativos e o único caminho de leitura é a URL assinada.
- **Sem regra de expiração.** O Lifecycle contém apenas transição, atendendo à regra de que nenhum arquivo pode ser deletado.
- **Arquivos pequenos na versão inicial.** O escopo prevê PDFs pequenos enviados pela API. O API Gateway aceita payloads de até 10 MB e o Lambda, em invocação síncrona, até 6 MB, o que limita o tamanho de cada envio. Para arquivos maiores, a evolução natural é a Lambda devolver uma URL assinada de upload e o cliente enviar direto ao S3 (fluxo descrito na seção 4.5).

4.4 Endpoints

Tabela 6 – Endpoints da API

Método	Rota	Função
POST	`/documentos`	Envia um PDF e grava em `{userId}/{uuid}.pdf`
GET	`/documentos`	Lista os documentos do usuário autenticado
GET	`/documentos/{id}`	Retorna metadados e URL assinada do documento

Fonte: elaborado pelos autores (2026).

4.5 Organização e fluxo dos dados

Os objetos são organizados por identificador interno do usuário. O nome do arquivo não é usado como identificador, pois pode se repetir: o backend gera uma chave única (UUID) e, em evolução futura, guarda metadados mínimos (ID do documento, proprietário, data de envio e estado de arquivamento). O prefixo organiza os dados, mas **não é, sozinho, a barreira de segurança**: o backend valida a identidade autenticada e a propriedade do documento em toda operação.

Fluxo de envio implementado (documentos pequenos)

1. O cliente autenticado envia o PDF por `POST /documentos`.
2. O API Gateway valida o token; a Lambda confere o tamanho (até 5 MB) e a assinatura `%PDF`.
3. A Lambda grava o objeto em `{userId}/{uuid}.pdf`, com criptografia SSE-KMS, e devolve o ID.

Fluxo de envio recomendado para evolução (arquivos maiores)

1. O cliente solicita o início do envio ao API Gateway.
2. A Lambda valida a identidade e as regras de negócio, gera uma chave controlada pelo servidor e devolve uma URL assinada de upload, de validade curta e restrita àquele objeto.
3. O cliente envia o PDF diretamente ao S3 por HTTPS, sem trafegar o conteúdo pela Lambda.
4. A aplicação registra o resultado e disponibiliza o documento na lista do proprietário.

Fluxo de consulta

1. O cliente solicita um documento pelo endpoint `GET /documentos/{id}`.
2. A Lambda identifica o usuário autenticado e monta a chave sempre com o prefixo dele.
3. Se o objeto estiver em classe de acesso imediato, a Lambda devolve uma URL assinada temporária.
4. Se o objeto estiver arquivado, a API informa a condição (HTTP 409). O fluxo de restauração proposto está na seção 8.4.

4.6 Justificativa técnica e alternativas

Tabela 7 – Decisões de projeto e alternativas consideradas

Decisão	Motivo	Alternativa / limitação
Arquitetura serverless	Reduz a administração de servidores e acompanha variações de demanda.	EC2 com aplicação própria daria mais controle, mas exigiria manutenção, escalabilidade e correções do sistema operacional.
S3 como repositório principal	Adequado para armazenar arquivos e aplicar políticas de ciclo de vida.	Sistema de arquivos ou banco relacional não são a opção mais simples para grande volume de PDFs e imagens.
URL pré-assinada	Permite upload/download temporário sem tornar o bucket público.	Enviar todos os bytes pela API/Lambda adiciona custo, latência e limites de payload; por isso o envio direto ao S3 é a evolução recomendada.
Arquivamento após 365 dias	Alinha a classe de armazenamento à redução esperada de acessos após um ano.	Classes de arquivamento exigem restauração e têm cobrança e prazos próprios.
Prefixo por usuário + autorização no backend	Organiza e separa os documentos por cliente.	Prefixo isolado não basta: a autorização ocorre em cada operação e as permissões IAM são restritas.
Sem expiração automática	Preserva o valor histórico indicado no case.	O custo total continua crescendo com o volume acumulado; é preciso acompanhar armazenamento, requisições, recuperação e logs.

Fonte: elaborado pelos autores (2026).

A classe de destino foi escolhida comparando custo por GB, cobrança de transição, duração mínima de armazenamento, custo de recuperação e tempo de disponibilização. O S3 Glacier Deep Archive é adequado a dados raramente acessados e com tolerância a espera maior; uma classe Glacier de recuperação mais rápida (Instant ou Flexible Retrieval) é preferível se a experiência do cliente exigir menor espera.

5. Implementação

5.1 Bucket S3

Configurações aplicadas ao bucket `nuvemtech-documentos`:

- **Block Public Access:** todas as opções ativadas.
- **Criptografia padrão:** SSE-KMS (ou SSE-S3, como alternativa de menor custo).
- **Versionamento:** habilitado, para proteger contra sobrescrita acidental.
- **Propriedade de objetos:** Bucket owner enforced (ACLs desabilitadas).
- **Política de bucket** que nega tráfego sem TLS:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyInsecureTransport",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:*",
      "Resource": [
        "arn:aws:s3:::nuvemtech-documentos",
        "arn:aws:s3:::nuvemtech-documentos/*"
      ],
      "Condition": { "Bool": { "aws:SecureTransport": "false" } }
    }
  ]
}
```

5.2 Organização por prefixo

```
nuvemtech-documentos/
├── usuario-123/
│   ├── 8f1c...e2.pdf
│   └── a47b...90.pdf
└── usuario-456/
    └── c03d...71.pdf
```

O nome do arquivo é um UUID gerado pelo servidor, evitando colisões e a exposição de nomes originais na chave.

Figura 2 – Isolamento de usuários por prefixo no S3 (a chave do objeto nasce do token, nunca da requisição)



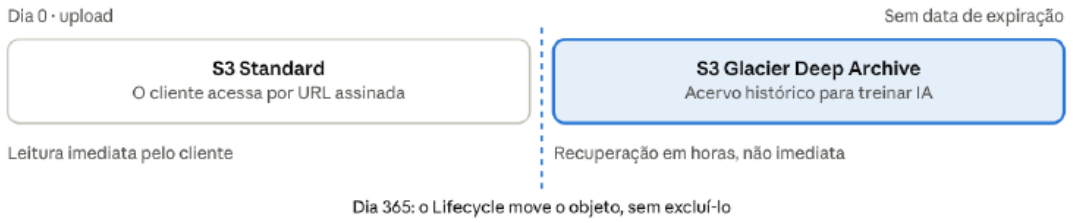
Fonte: elaborado pelos autores (2026).

5.3 Regra de Lifecycle

```
{
  "Rules": [
    {
      "ID": "arquivar-apos-365-dias",
      "Status": "Enabled",
      "Filter": { "Prefix": "" },
      "Transitions": [
        { "Days": 365, "StorageClass": "DEEP_ARCHIVE" }
      ],
      "NoncurrentVersionTransitions": [
        { "NoncurrentDays": 365, "StorageClass": "DEEP_ARCHIVE" }
      ]
    }
  ]
}
```

A regra não possui bloco `Expiration`, portanto nenhum objeto é removido. A classe de destino (Glacier Deep Archive) foi escolhida por ser a de menor custo por GB. Caso a equipe de IA precise recuperar dados com mais frequência, o Glacier Flexible Retrieval ou o Glacier Instant Retrieval são alternativas, com custo maior.

Figura 3 – Ciclo de vida dos documentos no S3 (após 365 dias o documento esfria e nunca é excluído)



Fonte: elaborado pelos autores (2026).

5.4 Permissões da função Lambda (IAM)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["s3:PutObject", "s3:GetObject"],
      "Resource": "arn:aws:s3:::nuvemtech-documentos/*"
    },
    {
      "Effect": "Allow",
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::nuvemtech-documentos"
    },
    {
      "Effect": "Allow",
      "Action": ["kms:GenerateDataKey", "kms:Decrypt"],
      "Resource": "arn:aws:kms:REGIAO:CONTA:key/ID-DA-CHAVE"
    },
    {
      "Effect": "Allow",
      "Action": ["logs:CreateLogGroup", "logs:CreateLogStream",
                 "logs:PutLogEvents"],
      "Resource": "*"
    }
  ]
}
```

Note que a função não possui `s3:DeleteObject` nem `s3:PutLifecycleConfiguration`. Assim, mesmo um bug ou um comprometimento do código não consegue apagar documentos. O bloco de KMS é necessário quando o bucket usa SSE-KMS: sem ele, a gravação e a geração de URLs assinadas de leitura falham; o ARN da chave deve ser substituído pelo da conta. Para o fluxo de restauração proposto (seção 8.4), seria acrescentada a permissão `s3:RestoreObject`.

Reforço de isolamento (recomendado). A role acima permite acessar qualquer prefixo; o isolamento depende do código. Para impor o isolamento também na camada de permissão, a Lambda pode assumir, a cada requisição, uma role via `sts:AssumeRole` com uma session policy restrita a `nuvemtech-documentos/{userId}/*`. Dessa forma, o próprio IAM nega qualquer acesso fora do prefixo do usuário.

5.5 Código da função Lambda (Python)

```
import base64
import json
import os
import uuid

import boto3
from botocore.config import Config

BUCKET = os.environ["BUCKET_NAME"]
URL_TTL = int(os.environ.get("URL_TTL_SECONDS", "300"))
MAX_BYTES = 5 * 1024 * 1024

s3 = boto3.client("s3", config=Config(signature_version="s3v4"))


def resposta(status, corpo):
    return {
        "statusCode": status,
        "headers": {"Content-Type": "application/json"},
        "body": json.dumps(corpo),
    }


def user_id(event):
    # ID vindo das claims validadas pelo autorizador, nunca do corpo
    claims = event["requestContext"]["authorizer"]["claims"]
    return claims["sub"]


def handler(event, context):
    uid = user_id(event)
    prefixo = f"{uid}/"
    metodo = event["httpMethod"]
    params = event.get("pathParameters") or {}

    if metodo == "POST":
        if event.get("isBase64Encoded"):
            dados = base64.b64decode(event["body"])
        else:
            dados = event["body"].encode()
        if len(dados) > MAX_BYTES or not dados.startswith(b"%PDF"):
            return resposta(400, {"erro": "Envie um PDF de até 5 MB"})
        doc_id = str(uuid.uuid4())
        s3.put_object(
```

```
            Bucket=BUCKET,
            Key=f"{prefixo}{doc_id}.pdf",
            Body=dados,
            ContentType="application/pdf",
            ServerSideEncryption="aws:kms",
        )
        return resposta(201, {"id": doc_id})

    if metodo == "GET" and params.get("id"):
        doc_id = params["id"]
        if not doc_id.replace("-", "").isalnum():
            return resposta(400, {"erro": "ID inválido"})
        # prefixo sempre do usuário autenticado
        chave = f"{prefixo}{doc_id}.pdf"
        try:
            meta = s3.head_object(Bucket=BUCKET, Key=chave)
        except s3.exceptions.ClientError:
            return resposta(404, {"erro": "Documento não encontrado"})
        if meta.get("StorageClass", "STANDARD") in ("GLACIER", "DEEP_ARCHIVE"):
            return resposta(409, {"erro": "Documento arquivado"})
        url = s3.generate_presigned_url(
            "get_object",
            Params={"Bucket": BUCKET, "Key": chave},
            ExpiresIn=URL_TTL,
        )
        return resposta(200, {"id": doc_id,
                              "tamanho": meta["ContentLength"],
                              "url": url})

    if metodo == "GET":
        lista = s3.list_objects_v2(Bucket=BUCKET, Prefix=prefixo)
        itens = [
            {"id": o["Key"][len(prefixo):-4],
             "tamanho": o["Size"],
             "data": o["LastModified"].isoformat()}
            for o in lista.get("Contents", [])
        ]
        return resposta(200, {"documentos": itens})

    return resposta(405, {"erro": "Método não permitido"})
```

Pontos de segurança do código: o prefixo é montado a partir da identidade autenticada; o ID do documento é validado antes de compor a chave, evitando manipulação de caminho (por exemplo `../`); o conteúdo é verificado como PDF; e a URL assinada expira em poucos minutos. **Limitações conhecidas:** a listagem não pagina resultados (máximo de 1.000 itens por chamada) e a versão inicial aceita apenas PDF, embora o case mencione também imagens; ambos os pontos constam em Melhorias Futuras.

6. Estimativa de Custos

O exercício a seguir usa premissas e valores de referência aproximados, devendo ser recalculado na AWS Pricing Calculator com os preços atuais da região escolhida, registrando a data da simulação.

6.1 Premissas

Tabela 8 – Premissas da estimativa de custos

Variável	Valor adotado	Observação
Novos arquivos por mês	50.000	Informado no case.
Arquivos por ano	≈ 600.000	Mantido o ritmo mensal.
Tamanho médio do arquivo	500 KB (≈ 25 GB por mês)	Premissa da equipe; **medir em amostra real** antes da proposta final.
Região AWS	us-east-1	Afeta os preços; revisar se os dados precisarem ficar no Brasil.
S3 Standard	≈ US$ 0,023 / GB-mês	Preço de referência.
S3 Glacier Deep Archive	≈ US$ 0,001 / GB-mês	Preço de referência.
Consultas e downloads mensais	A levantar	Afetam requisições e custos de transferência e recuperação.
Retenção de logs	A definir	Afeta o custo operacional do CloudWatch e do CloudTrail.

Fonte: elaborado pelos autores (2026).

6.2 Resultado da simulação

Tabela 9 – Estimativa de custos mensais de armazenamento

Mês	Acervo acumulado	Só S3 Standard	Com Lifecycle (365 dias)
12	≈ 300 GB	≈ US$ 6,90	≈ US$ 6,90
24	≈ 600 GB	≈ US$ 13,80	≈ US$ 7,20
36	≈ 900 GB	≈ US$ 20,70	≈ US$ 7,50
60	≈ 1,5 TB	≈ US$ 34,50	≈ US$ 8,10

Fonte: elaborado pelos autores (2026).

No cenário com Lifecycle, apenas os últimos 12 meses permanecem no Standard (≈ 300 GB), e o restante vai para o Deep Archive. A economia cresce com o tempo: ao fim de 5 anos, o custo mensal de armazenamento é cerca de 76% menor. A linha do mês 24 foi acrescentada para completar a série; o cálculo segue as mesmas premissas.

6.3 Pontos de atenção nos custos

- **Taxa por transição:** cada objeto movido para o Glacier gera uma cobrança por requisição de transição. Com 50 mil objetos por mês, o valor é baixo, mas deve entrar no cálculo.
- **Objetos pequenos:** classes Glacier acrescentam metadados por objeto (cerca de 40 KB, entre cobrança no Glacier e no Standard) e há cobrança mínima de 90 a 180 dias de permanência, conforme a classe. Para milhões de arquivos muito pequenos, vale avaliar o agrupamento dos documentos em lotes (por exemplo, arquivos `.tar` por cliente e mês) antes do arquivamento.
- **Recuperação:** ler dados do Deep Archive tem custo e prazo. O uso para treinamento de modelos deve ser planejado em lotes.
- **Demais serviços:** API Gateway, Lambda e KMS cobram por uso e, neste volume, representam parcela pequena do total.

6.4 Estratégias de otimização

- Aplicar a transição para arquivamento após 365 dias, conforme o requisito.
- Escolher a classe de arquivamento a partir do padrão de acesso e do tempo de recuperação aceitável.
- Evitar transferir o conteúdo do arquivo pela Lambda; preferir URL assinada e upload/download direto ao S3.
- Definir retenção adequada para logs e métricas, evitando coleta excessiva.
- Monitorar armazenamento, requisições e restaurações com alertas do AWS Budgets e o AWS Cost Explorer.

7. Segurança e Conformidade

7.1 Controles de segurança

Tabela 10 – Controles de segurança

Controle	Como é atendido
Isolamento entre clientes	Prefixo por usuário, ID extraído do token e, opcionalmente, session policy por prefixo
Sem exposição pública	Block Public Access ativo e ACLs desabilitadas
Acesso do dono	URL assinada de curta duração gerada pela Lambda
Criptografia	TLS em trânsito (política de bucket) e SSE-KMS em repouso
Menor privilégio	Role da Lambda sem permissões de exclusão ou de alteração de Lifecycle
Rastreabilidade	CloudTrail (eventos de dados do S3) e CloudWatch Logs
Proteção contra perda	Versionamento e, como evolução, S3 Object Lock

Fonte: elaborado pelos autores (2026).

7.2 Identidade e autorização

A autenticação pode ser integrada ao mecanismo de identidade já utilizado pela plataforma SaaS. Na ausência de um, o Amazon Cognito é a opção adotada nesta proposta e deve ser validada pelo grupo. O API Gateway encaminha ao backend a identidade verificada; a Lambda autoriza a operação com base nessa identidade e na propriedade do documento.

7.3 Boas práticas adicionais

- Gerar URLs assinadas com validade curta, escopo restrito e somente após autorização do proprietário.
- Não registrar em logs tokens, URLs assinadas completas, conteúdo de arquivos ou dados pessoais desnecessários.
- Restringir e auditar ações administrativas, incluindo alteração de políticas e tentativas de exclusão.
- Definir política de retenção de logs e de acesso operacional compatível com a necessidade de auditoria.

7.4 Preservação e proteção contra exclusão

A exigência do case é que nenhum arquivo seja deletado. Por isso, a regra Lifecycle realiza somente a transição de classe, sem expiração automática. Para reduzir exclusões acidentais, a permissão `s3:DeleteObject` é restringida por IAM e as funções operacionais são separadas. O versionamento ajuda a recuperar sobrescritas e exclusões, mas não impede por si

só toda exclusão definitiva; se for necessária imutabilidade formal, deve-se avaliar o S3 Object Lock e definir o modo e o período de retenção.

7.5 Considerações sobre a LGPD

A regra "nunca deletar" e o uso dos documentos para treinar IA exigem atenção à Lei Geral de Proteção de Dados: base legal e consentimento claros nos termos de uso, finalidade informada ao cliente, e um processo para atender pedidos de exclusão de titulares. Esse último ponto entra em tensão com a retenção perpétua e deve ser tratado com a área jurídica; tecnicamente, recomenda-se anonimização ou pseudonimização antes do uso em treinamento. Esta seção é uma reflexão técnica, não substitui parecer jurídico.

8. Escalabilidade, Resiliência e Recuperação

8.1 Crescimento da demanda

A estimativa de 50 mil arquivos por mês equivale a cerca de 600 mil por ano. Com a premissa de 500 KB por arquivo, isso representa aproximadamente 300 GB por ano. O tamanho médio real precisa ser medido, pois é a principal variável do custo.

API Gateway e Lambda são serviços gerenciados que acompanham variações de tráfego dentro de suas cotas e limites. O S3 foi projetado para armazenar grandes volumes de objetos. Ainda assim, a solução deve monitorar erros, concorrência da Lambda, throttling e latência; se houver picos relevantes, as cotas devem ser avaliadas antes da entrada em produção.

8.2 Resiliência e falhas

- Se uma invocação da Lambda falhar, a aplicação retorna uma mensagem controlada, registra o erro e permite nova tentativa segura.
- Os uploads usam chaves únicas (UUID), o que evita sobrescritas acidentais em reenvios.
- A equipe deve definir como identificar envios incompletos e limpar metadados de operações não concluídas, sem apagar documentos históricos válidos.
- Os serviços gerenciados reduzem a administração de instâncias, mas não eliminam falhas de configuração, indisponibilidades regionais ou limites de serviço.
- Para requisitos de continuidade mais rigorosos, avaliar replicação entre regiões e cópias independentes, após análise de custo, residência dos dados e objetivo de recuperação.

8.3 Proteção dos dados

A preservação do acervo é apoiada pela ausência de expiração automática, pela restrição das permissões de exclusão e, conforme a política aprovada, pelo versionamento e por controles de imutabilidade. Esses mecanismos têm funções diferentes: o versionamento ajuda a recuperar versões anteriores, enquanto o Object Lock pode impor retenção contra exclusão ou alteração. A estratégia deve ser validada por testes.

8.4 Recuperação de documentos arquivados

Objetos em classes como Glacier Deep Archive não podem ser lidos imediatamente. Na versão atual, a API responde HTTP 409 ("Documento arquivado"). Como evolução **proposta, ainda não implementada**, o fluxo seria:

1. O cliente solicita a restauração (por exemplo, `POST /documentos/{id}/restauracao`).
2. A Lambda confirma a propriedade do documento e chama `RestoreObject`, criando uma cópia temporária por um número de dias definido.
3. A aplicação informa ao usuário que a restauração está em andamento; o prazo depende da classe e da opção de recuperação escolhidas (no Deep Archive, em até 12 h no padrão e em até 48 h em massa).
4. Concluída a restauração, a URL assinada passa a ser emitida normalmente.

Por isso, não deve ser prometido um tempo fixo ao cliente sem a seleção definitiva da classe e a validação do procedimento.

8.5 Objetivos de recuperação

O RPO (perda de dados aceitável) e o RTO (tempo máximo aceitável para restabelecer o serviço) não foram definidos no enunciado.

Tabela 11 – Cenários de falha e resposta planejada

Cenário	Resposta planejada	Validação necessária
Erro de aplicação	Corrigir ou reverter a função e monitorar falhas no CloudWatch.	Testar a resposta de erro e a recuperação do endpoint.
Exclusão ou sobrescrita indevida	Recuperar a versão anterior (versionamento) e revisar permissões.	Executar teste controlado em ambiente de demonstração.
Documento arquivado solicitado	Iniciar a restauração e liberar o acesso após a conclusão.	Medir o tempo real conforme a classe selecionada.
Falha regional grave	Avaliar cópia ou replicação em outra região conforme RTO/RPO aprovados.	Definir custo e realizar exercício de recuperação, se implementado.

Fonte: elaborado pelos autores (2026).

9. Monitoramento e Operação

O Amazon CloudWatch acompanha logs e métricas do API Gateway e da Lambda. Recomenda-se alarmes para aumento de erros, latência, throttling e falhas de execução. O monitoramento do S3 e dos custos deve permitir observar o crescimento do acervo, a quantidade de solicitações e o uso das classes de armazenamento, com alertas de orçamento no AWS Budgets.

Como diferencial, recomenda-se documentar a infraestrutura e automatizar a criação dos recursos com AWS CDK, AWS SAM, Terraform ou AWS CloudFormation. A infraestrutura como código facilita a repetição, a revisão e a recuperação do ambiente, mas só deve ser apresentada como implementada se houver evidências.

10. Plano de Testes e Validação

10.1 Casos de teste

Tabela 12 – Plano de testes

Teste	Resultado esperado
Envio de PDF válido com usuário A	201 e objeto em `A/{uuid}.pdf`
Envio de arquivo que não é PDF	400
Usuário A consulta documento do usuário B	404 (a chave é sempre montada com o prefixo de A)
Acesso direto à URL do objeto sem assinatura	403
Uso da URL assinada após expirar	403
Tentativa de ID com `../`	400
Requisição sem token válido	401 ou 403, barrada pelo autorizador
Tentativa de exclusão de objeto com a role da Lambda	Acesso negado (sem `s3:DeleteObject`)
Consulta de documento já arquivado	409 ("Documento arquivado")
Verificação do bucket com o IAM Access Analyzer	Nenhum achado de acesso público
Simulação do Lifecycle (objeto de teste com regra de 1 dia)	Classe do objeto alterada para a camada fria; objeto não excluído

Fonte: elaborado pelos autores (2026).

Os três testes intermediários (sem token, exclusão e documento arquivado) foram acrescentados ao plano original para cobrir autenticação, preservação e arquivamento. A simulação do Lifecycle deve usar apenas objeto de teste e regra temporária, sem alterar a política de produção.

10.2 Mapeamento dos requisitos

Tabela 13 – Mapeamento entre requisitos, solução e demonstração

Requisito	Como será atendido	Como demonstrar
Upload de documentos	API Gateway + Lambda; gravação no S3 sob o prefixo do usuário.	Enviar um PDF de teste e confirmar a presença do objeto no bucket.
Acesso individual	Autenticação, prefixo vindo do token e URL temporária.	Testar dois usuários e comprovar que um não acessa o documento do outro.
Bucket não público	Block Public Access ativado e políticas restritivas.	Mostrar as configurações do bucket e testar o acesso não autorizado.
Preservação histórica	Sem regra de expiração; sem `DeleteObject`; versionamento.	Revisar as regras de Lifecycle e as políticas; explicar os controles contra exclusão.
Arquivamento aos 365 dias	Regra de Lifecycle para transição, sem expiração.	Mostrar a regra; usar objeto de teste com regra temporária.

Requisito	Como será atendido	Como demonstrar
Escalabilidade	API Gateway, Lambda e S3 gerenciados.	Mostrar métricas de requisições e invocações, ou explicar o comportamento esperado se não houver teste de carga.
Monitoramento	CloudWatch Logs, métricas e alarmes.	Mostrar logs e um alarme de teste, se implementado.

Fonte: elaborado pelos autores (2026).

11. Melhorias Futuras

- Upload direto ao S3 por URL assinada, removendo o limite de 6 MB da Lambda.
- Suporte a imagens (PNG, JPEG) além de PDFs, com validação por tipo de conteúdo.
- Paginação na listagem de documentos (`ContinuationToken`).
- Fluxo de restauração de documentos arquivados, conforme a seção 8.4.
- Processamento assíncrono com eventos do S3, SQS e Lambda para acionar o Agente de IA.
- Replicação entre regiões (Cross-Region Replication) para recuperação de desastres.
- S3 Object Lock para imutabilidade formal do acervo.
- Uso de S3 Intelligent-Tiering para dados com padrão de acesso imprevisível.
- Catálogo de metadados (DynamoDB) para buscas rápidas sem listar o bucket.
- Pipeline de dados anonimizados para treinamento dos modelos.
- Infraestrutura como código (AWS CDK, SAM ou Terraform) e CI/CD.
- Dashboards e alarmes de observabilidade e custo; testes de carga e de segurança antes da disponibilização para clientes reais.

12. Conclusão

A arquitetura proposta atende aos requisitos da NuvemTech: recebe documentos por uma API gerenciada, armazena-os no S3 com isolamento por usuário, impede qualquer acesso público e entrega os arquivos apenas por URLs assinadas de curta duração. A regra de Lifecycle move automaticamente os objetos com mais de 365 dias para uma camada de baixo custo, mantendo o acervo histórico íntegro para o treinamento de futuros modelos de IA e tornando o crescimento sustentável do ponto de vista financeiro.

A principal decisão de segurança é não tratar o prefixo do objeto como única barreira: cada consulta valida a identidade e a propriedade do documento antes de emitir uma URL temporária. A principal decisão de custo é alinhar a classe de armazenamento ao padrão de acesso, considerando o custo e o prazo de restauração.

O projeto demonstra como serviços serverless e recursos nativos do S3 permitem equilibrar segurança, custo e escala sem operar infraestrutura própria, o que é decisivo para uma startup em hipercrescimento. Como próximos passos, recomenda-se validar as estimativas de custo com dados reais de tamanho de arquivo, fortalecer o isolamento com session policies por prefixo, definir RPO e RTO, testar a restauração de arquivos e estabelecer, junto ao jurídico, a política de retenção frente à LGPD.

Referências

AWS. **Amazon S3 User Guide: Managing your storage lifecycle.** Documentação oficial da AWS.

AWS. **Amazon S3 User Guide: Blocking public access to your Amazon S3 storage.** Documentação oficial da AWS.

AWS. **Amazon S3 User Guide: Sharing objects with presigned URLs.** Documentação oficial da AWS.

AWS. **Amazon S3 User Guide: Restoring an archived object; Locking objects with Object Lock.** Documentação oficial da AWS.

AWS. **Amazon S3 storage classes.** Documentação oficial da AWS.

AWS. **AWS Lambda Developer Guide** e **Amazon API Gateway Developer Guide.** Documentação oficial da AWS.

AWS. **AWS Identity and Access Management User Guide** e **Amazon CloudWatch User Guide.** Documentação oficial da AWS.

AWS. **AWS Well-Architected Framework:** Security Pillar e Cost Optimization Pillar.

AWS. **AWS Pricing Calculator** e páginas de preços do Amazon S3.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018** (Lei Geral de Proteção de Dados Pessoais).

ESCOLA DA NUVEM. **Manual do Aluno: Projeto TCC AWS – Guia Completo para Entrega e Apresentação.** Material fornecido pela formação.

ESCOLA DA NUVEM. **Cases Cloud – Case 2: A Jornada da Startup (Gestão de Documentos para IA).** Material fornecido pela formação.

Glossário

Tabela 14 – Glossário de termos

Termo	Significado
ABAC	Controle de acesso baseado em atributos, como o ID do usuário
Block Public Access	Recurso do S3 que bloqueia qualquer acesso público ao bucket
Bucket	Contêiner de objetos no Amazon S3
Deep Archive	Classe do S3 Glacier de menor custo, para retenção de longo prazo
JWT	Token assinado que carrega a identidade do usuário
Lifecycle	Regras que movem objetos entre classes de armazenamento ao longo do tempo
Object Lock	Recurso do S3 que impõe retenção contra exclusão ou alteração de objetos
Prefixo	Início da chave de um objeto, usado para agrupar arquivos por usuário
Restauração	Processo de tornar legível, temporariamente, um objeto arquivado no Glacier
RPO	Perda de dados máxima aceitável, medida em tempo
RTO	Tempo máximo aceitável para restabelecer o serviço após uma falha
Serverless	Modelo em que o provedor gerencia os servidores e a cobrança é por uso
Throttling	Limitação da taxa de requisições para proteger o serviço
URL assinada	Link temporário que dá acesso a um único objeto
Versionamento	Recurso do S3 que guarda versões anteriores de um objeto

Fonte: elaborado pelos autores (2026).